Zero-Trust IoT Network: Identity and Authorization Policy

Project: Evaluating Zero-Trust Security in IoT Networks
Team Member: Nephie Douyon
Responsibility: Device Permissions and Preventive Security Controls

1. Purpose

The purpose of this document is to establish identity verification and authorization policies for the IoT devices in our simulated network. These policies follow the Zero-Trust security principle that devices should not automatically receive access to network resources simply because they are connected.

Our approach focuses on verifying device registration, restricting communication to approved destinations, and preventing unauthorized access. These policies will also support the team's trust-scoring system by establishing which device activities should be considered authorized or unauthorized.

2. Device Identity Verification

Before a device is permitted to access protected network resources, its identity must be checked against the approved device inventory.

For our simulation, device registration will be determined using identifiers recorded in the inventory, such as IP addresses or MAC addresses. The specific identifiers will be confirmed using the Cisco Packet Tracer network configuration.

The proposed identity verification process is:

1. Identify the device requesting access.
2. Compare its identifier against the approved device inventory.
3. Determine whether the device is registered or unknown.
4. Record the identity-check result for use in authorization decisions and trust scoring.

The Smart Camera, Motion Sensor, Thermostat, and Door Lock are expected to be registered devices. The Rogue Device represents an unknown or unauthorized device during testing.

Limitation: IP and MAC addresses alone do not provide strong authentication because they can potentially be spoofed. Therefore, our simulation's inventory-based verification should not be treated as equivalent to cryptographic device authentication.

3. Device Authorization Policies

After checking device registration, the system must determine whether the requested communication is permitted.

A registered device should only communicate with destinations and services required for its assigned function.

Proposed Authorization Table

Device	Authorized Destination	Destination IP	Policy
Motion Sensor	IoT Server	192.168.30.10	Permit approved sensor communication
Smart Camera	Video Server	192.168.30.20	Permit approved video communication
Thermostat	IoT Server	192.168.30.10	Permit approved temperature-control communication
Door Lock	IoT Server	192.168.30.10	Permit approved door-control communication
Rogue Device	None	N/A	Deny access to protected resources

These destinations follow Bryan's documented normal-device behavior. Source addresses, communication protocols, service ports, and actual enforcement configurations still require confirmation.

The authorization policy will follow a default-deny approach for protected resources, with explicit permissions for necessary communication.

4. Least-Privilege Access Control

The principle of least privilege requires that devices receive only the access necessary to perform their intended functions.

For example, the Smart Camera is expected to communicate with the Video Server. It should not automatically be authorized to communicate with the IoT Server.

Similarly, the Motion Sensor, Thermostat, and Door Lock are expected to communicate with the IoT Server, but they should not receive unrestricted access to unrelated network resources.

The team will investigate whether Access Control Lists (ACLs) can enforce these restrictions in Cisco Packet Tracer.

Network segmentation may also be considered if the simulated topology supports separating devices or protected resources into distinct network segments.

The final implementation will depend on the existing network architecture and the communication paths available for filtering.

5. Unauthorized Activity and Policy Violations

The authorization policies will help identify violations during the team's three controlled testing scenarios.

Scenario 1: Unknown Device Requests Access

The Rogue Device attempts to access a protected network resource without being registered in the approved device inventory.

Expected policy decision: Deny unauthorized access and record the identity and authorization failures.

Scenario 2: Registered Device Requests Unauthorized Access

A registered device attempts to communicate with a destination outside its approved permissions.

For example, the Smart Camera attempts to access the IoT Server rather than the Video Server.

Expected policy decision: Deny the unauthorized request even though the device is registered.

Scenario 3: Registered Device Exhibits Abnormal Behavior

A registered device begins behaving differently from its documented normal activity.

Expected policy decision: Evaluate the observed behavior against existing authorization rules. Unauthorized communication must remain denied, while suspicious activity that does not violate an access rule will be referred to the team's trust-scoring and response process.

6. Integration With the Trust-Scoring System

Bryan's trust-scoring system evaluates devices using registration status, normal or abnormal behavior, and authorization decisions.

The scoring rules are:

Condition	Score
Registered device	+2
Normal behavior	+2
Authorized destination	+1
Unknown device	-3
Abnormal traffic	-2
Unauthorized access	-3

Devices receiving a score of 3 or higher are classified as Trusted, scores from 0 to 2 as Suspicious, and scores below 0 as Untrusted.

Our authorization policies will provide the criteria for determining whether a destination or requested service is permitted.

A device's trust classification will not override mandatory authorization rules. Even if a device receives a Trusted classification, a request that violates the approved access policy must still be denied.

Trust scores will support detection and response decisions rather than replace access-control enforcement.

7. Proposed Preventive Security Controls

The following controls will be evaluated for the protected network:

Access Control Lists (ACLs): Restrict communication based on network addresses and, where supported, protocols and service ports.

Least Privilege: Limit devices to approved destinations and required services.

Network Segmentation: Separate devices or resources where practical to reduce unnecessary communication paths.

Device Registration Checks: Use the approved inventory to identify recognized and unknown devices during manual evaluation.

These controls have been proposed but have not yet been confirmed as fully implemented or tested.

8. Implementation and Verification Plan

In CISCO Packet Tracer:

1. Confirm device IP addresses, identifiers, and network connections.
2. Verify the approved destinations and required communication services.
3. Review the existing ACLs and determine where additional restrictions are necessary.
4. Implement the agreed preventive controls where supported by the topology.
5. Test that legitimate device communication remains functional.
6. Test that unauthorized communication is blocked.
7. Record configuration commands, screenshots, and test outcomes.
8. Compare the protected network against the baseline network.
9. Correct rules that unintentionally block authorized communication.

Testing results will be coordinated with Carina's network scenarios, Bryan's detection and scoring process, and Maria's response mechanisms.

9. Conclusion

The identity and authorization policies establish the foundation for preventive security in our simulated Zero-Trust IoT network. By identifying registered devices, defining approved communication destinations, and restricting unauthorized requests, the project aims to reduce unnecessary access to network resources.

These policies will guide the implementation of preventive controls and provide authorization criteria for the team's trust-scoring system. Their effectiveness will be evaluated through controlled testing in Cisco Packet Tracer.